

Default Credentials Scanning

LLM-supported application-level default
credential scanner

Laurenz Pepe Simon & Mathis Zscheischler

**Design IT.
Create Knowledge.**

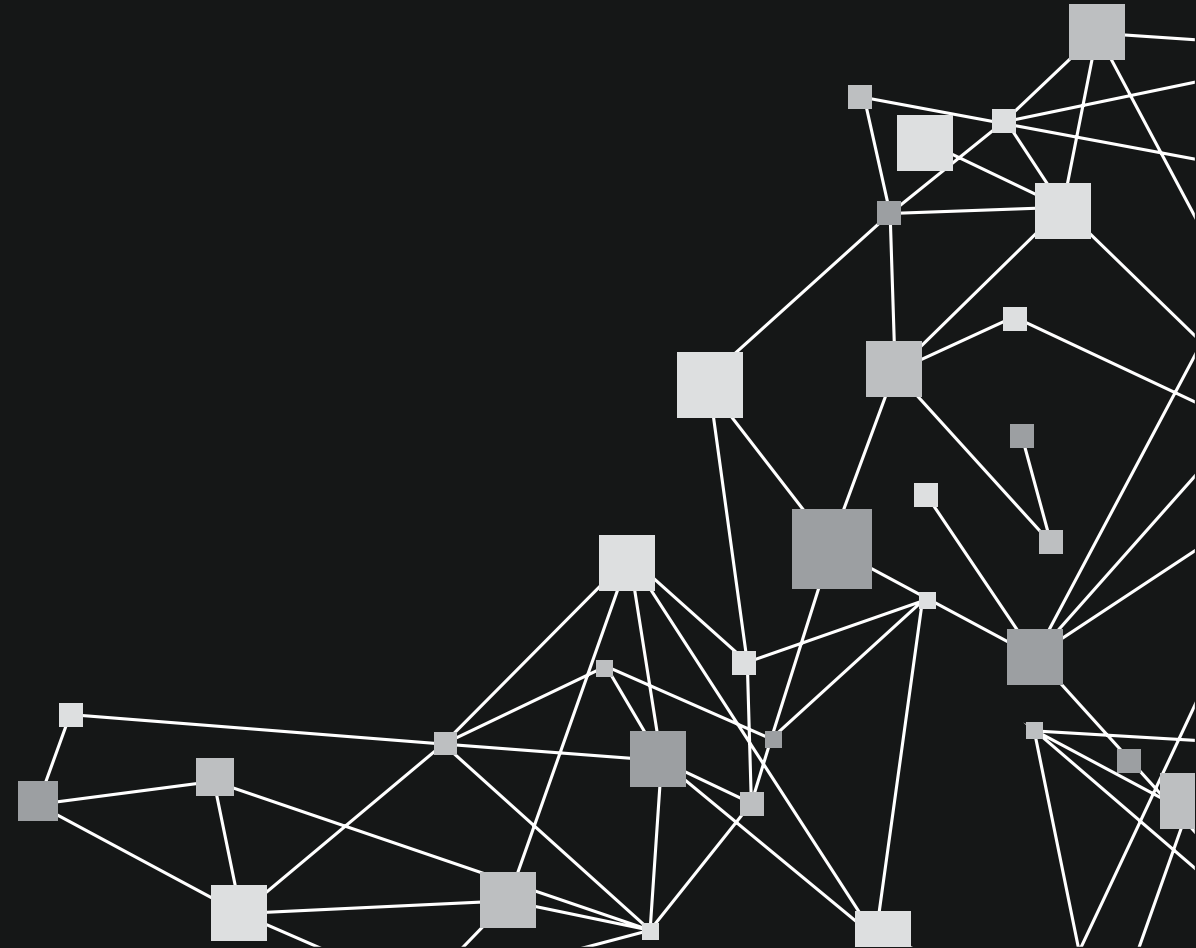
www.hpi.de



State of the Art

**Design IT.
Create Knowledge.**

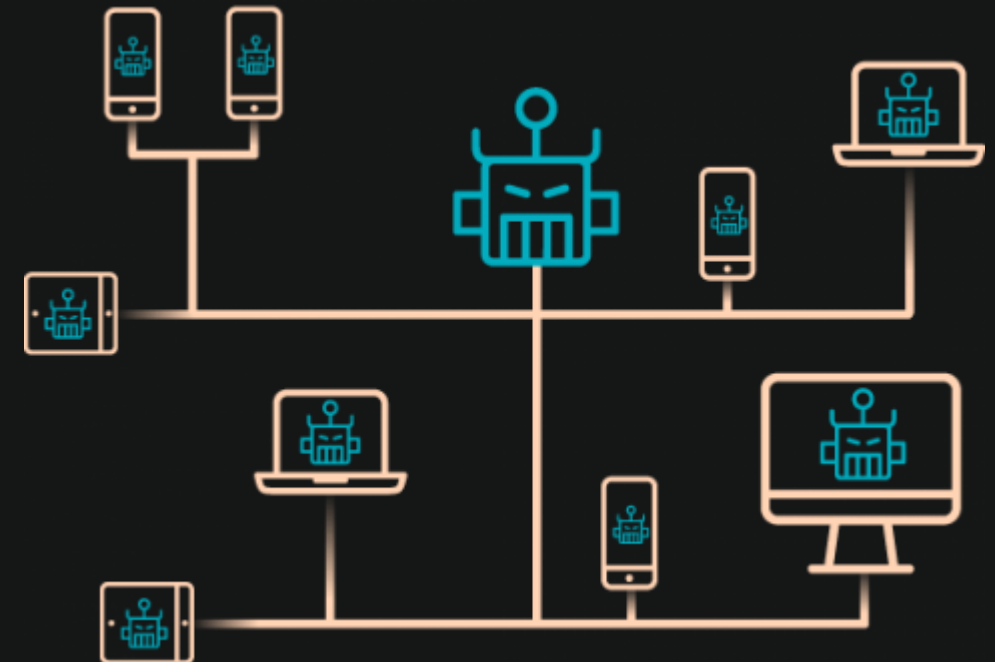
www.hpi.de



Mirai Botnet — Massive DDoS Attacks (2016)



- Scanned for IoT devices with default credentials
 - Added each to botnet
- botnet grew to hundreds of thousands of devices
 - record-setting DDoS attacks
 - outages for Twitter, Netflix, Reddit...



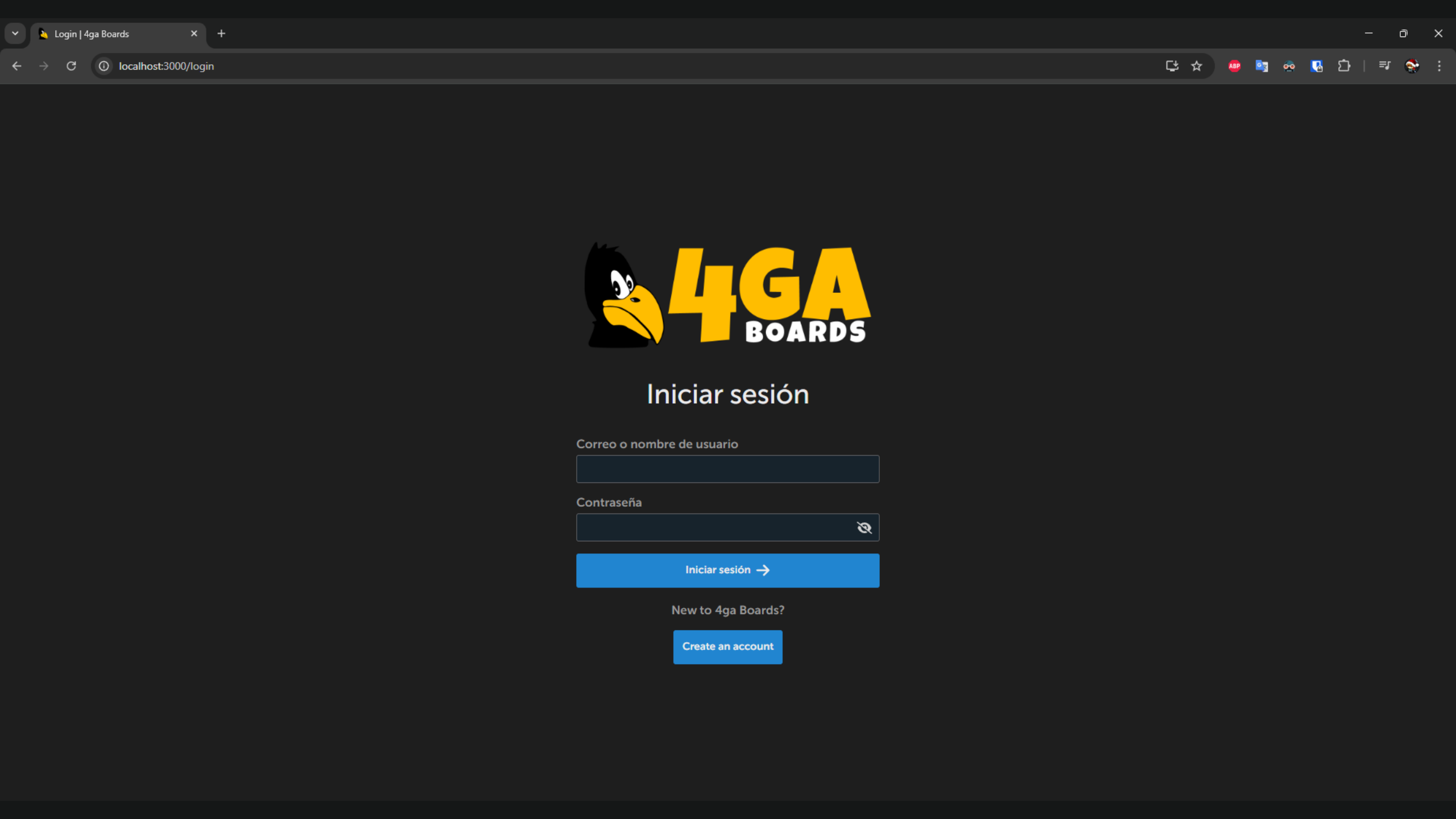
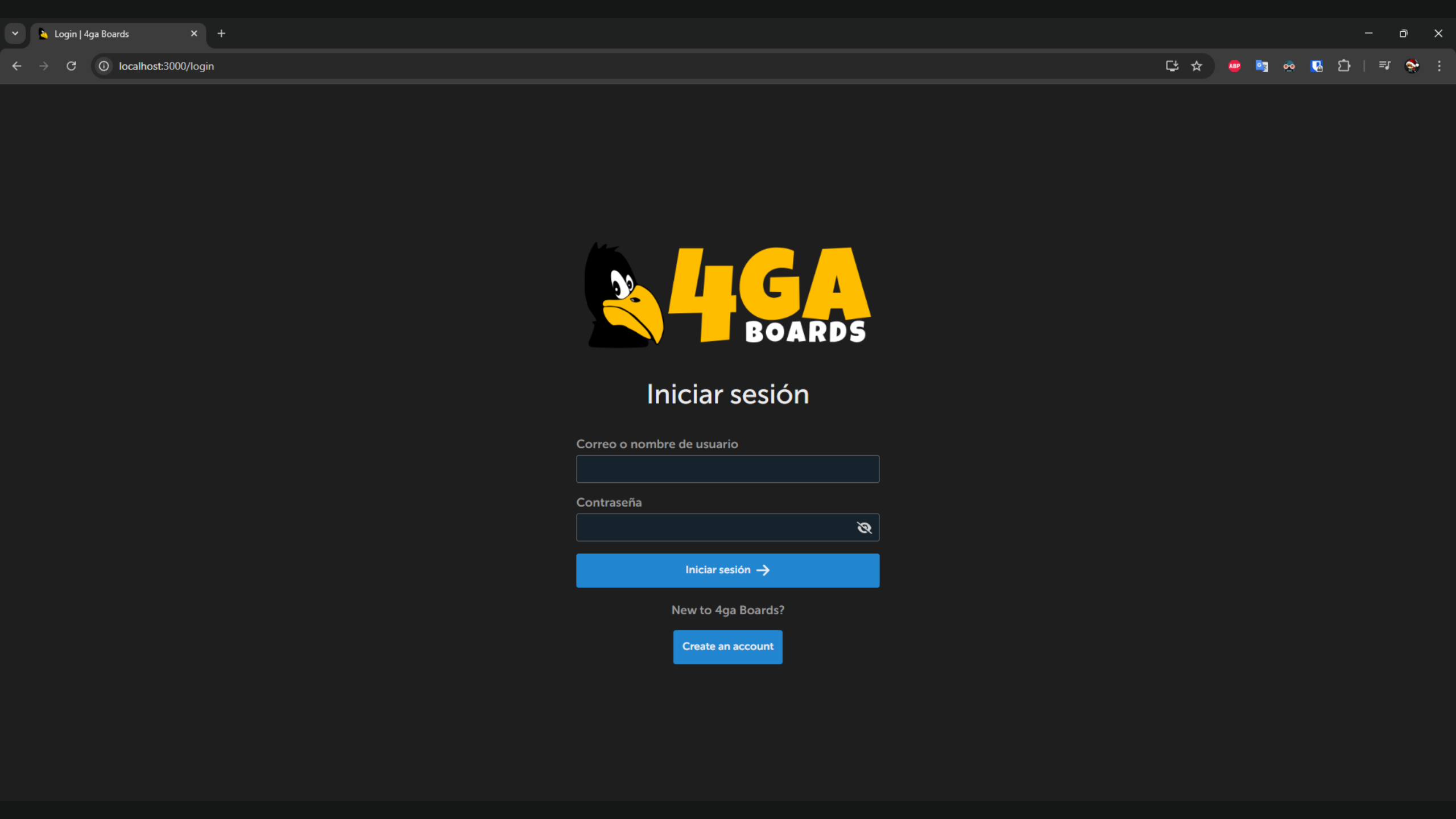
<https://www.myrasecurity.com/de/knowledge-hub/mirai/>

NMAP http-default-accounts script



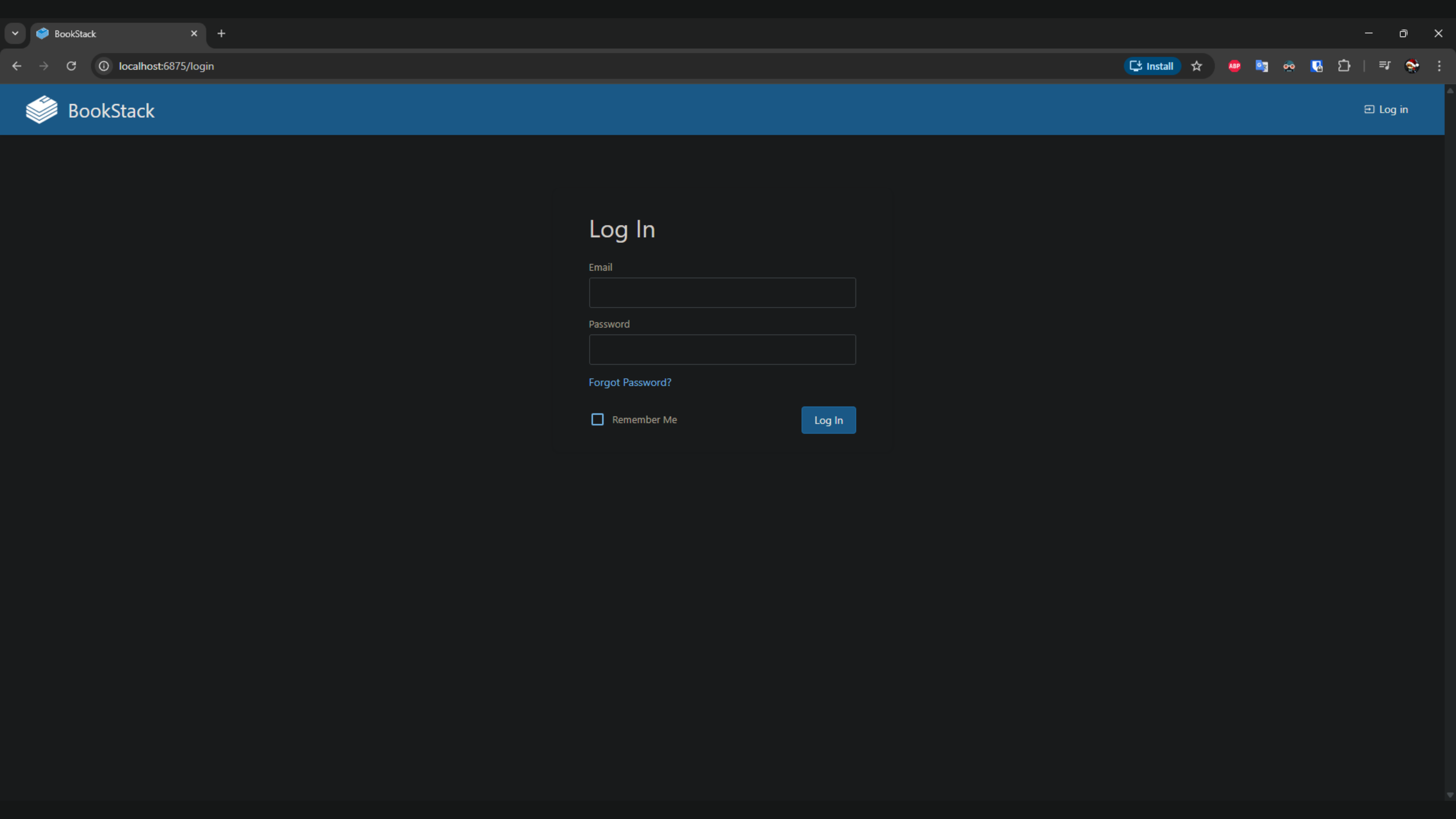
- "Tests for access with default credentials used by a variety of web applications and devices."
- Relies on fingerprint DB
(`nmap/nselib/data/http-default-accounts-fingerprints.lua`)





NMAP http-default-accounts script

```
● ● ●
PORT      STATE SERVICE VERSION
3000/tcp  open  ppp?
| fingerprint-strings:
|   DNSStatusRequestTCP, DNSVersionBindReqTCP, Help, NCP, RPCCheck, SSLSessionReq:
|     HTTP/1.1 400 Bad Request
|     Connection: close
|   GetRequest:
|     HTTP/1.1 200 OK
|     X-Powered-By: Sails <sailsjs.com>
|     Content-Type: text/html; charset=utf-8
|     Content-Length: 1148
|     ETag: W/"47c-V+EhG7/GT7+Vwu8br/iuD9Iy8Ak"
|     Vary: Accept-Encoding
|     Date: Sun, 15 Feb 2026 13:32:33 GMT
|     Connection: close
|     <!doctype html><html lang="en" data-color-mode="dark"><head><meta charset="utf-8"/><link rel="icon"
href="http://localhost:3000/favicon.ico"/><meta name="viewport" content="width=device-width,initial-scale=1"/><meta
name="theme-color" content="#22252a"/><meta name="description" content="4ga Boards - Straightforward boards system for
realtime project management"/><meta name="keywords" content="4ga Boards, 4ga Boards Instance, Project Management, Task
Management, Kanban Boards, Team Collaboration, Realtime, Todo List, Task List, Minimalistic Design, Multitasking"/>
<link rel="apple-touch-icon" href="http://localhost:3000/4gaboards192w.png"/><link rel="style
|   HTTPOptions, RTSPRequest:
|     HTTP/1.1 200 OK
|     X-Powered-By: Sails <sailsjs.com>
|     Date: Sun, 15 Feb 2026 13:32:33 GMT
|_    Connection: close
```



Log In

Email

Password

[Forgot Password?](#)

☐ Remember Me

Log In

NMAP http-default-accounts script



```
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00029s latency).
```

```
PORT      STATE SERVICE VERSION
6875/tcp  open  http    nginx
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Feb 15 14:34:15 2026 -- 1 IP address (1 host up) scanned in 11.70 seconds
```

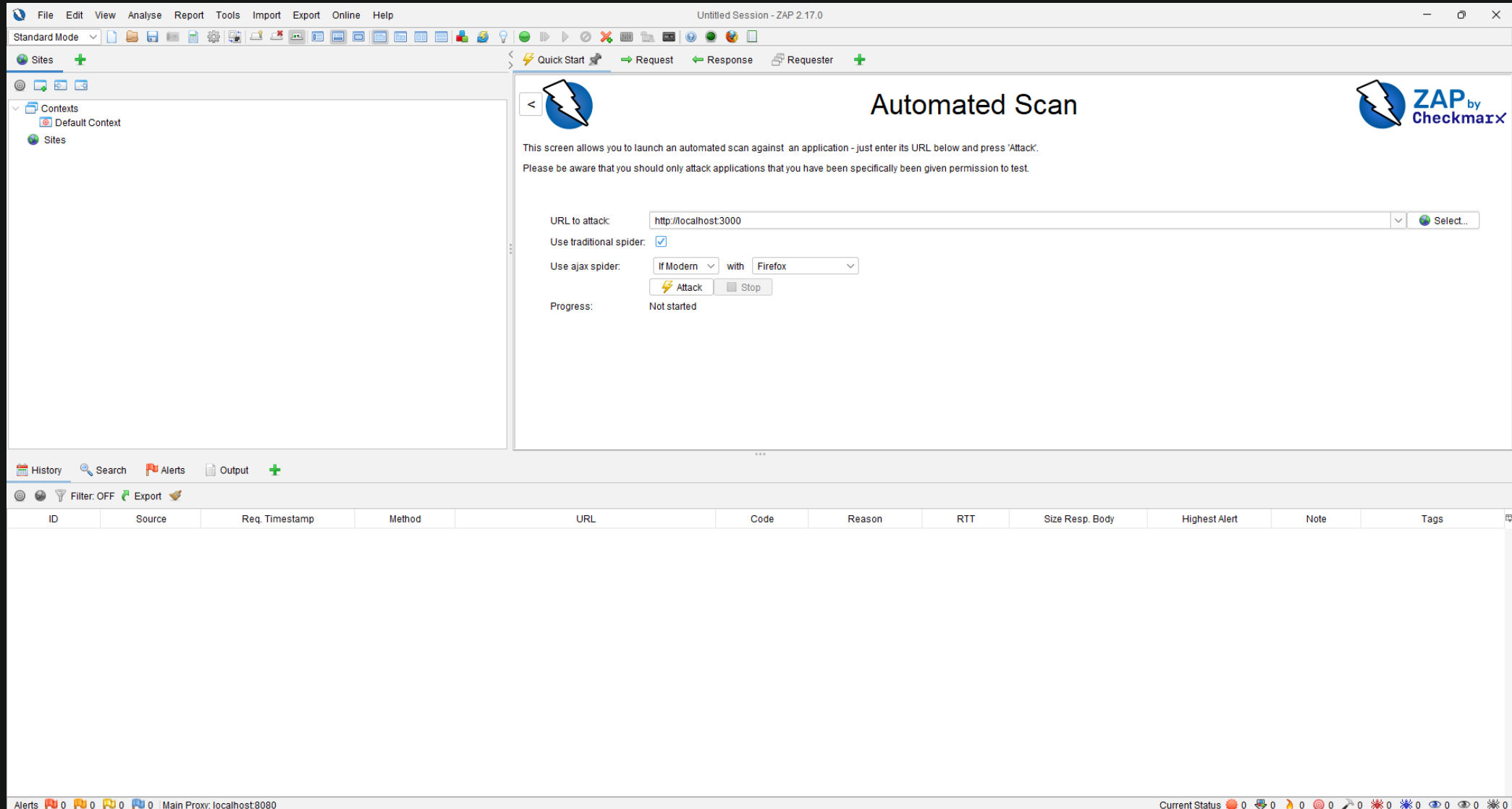
http-default-accounts-fingerprints-nndefaccts.lua

```
table.insert(fingerprints, {
  name = "Zebra Printer",
  category = "printer",
  paths = {
    {path = "/"},
  },
  target_check = function (host, port, path, response)
    return response.status == 200
      and response.body
      and response.body:find("Zebra Technologies", 1, true)
      and response.body:lower():find("<a%f[%s][^>]-%shref%s*=%s*(['\\\"])\nconfig%.html%1[^>]*>view printer\nconfiguration</a>")
  end,
  login_combos = {
    {username = "", password = "1234"}
  },
  login_check = function (host, port, path, user, pass)
    local resp = http_post_simple(host, port, url.absolute(path, "authorize"),
      nil, {[ "0" ] = pass})

    return resp.status == 200
      and (resp.body or ""):find(">Access Granted.", 1, true)
  end
})
```

13788 lines but
zero of our test
apps in this list!

- More sophisticated tools?
- OWASP ZAP



The screenshot shows the OWASP ZAP 2.17.0 interface. The main window is titled "Automated Scan" and contains the following elements:

- URL to attack:** A text input field containing "http://localhost:3000".
- Use traditional spider:** A checkbox that is checked.
- Use ajax spider:** A dropdown menu set to "If Modern" with a "with" dropdown set to "Firefox".
- Buttons:** "Attack" (with a lightning bolt icon) and "Stop".
- Progress:** A label indicating "Not started".

The left sidebar shows the "Sites" tree with "Default Context" and "Sites". The bottom status bar shows "Alerts 0", "Main Proxy: localhost:8080", and "Current Status" with various icons.

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
----	--------	----------------	--------	-----	------	--------	-----	-----------------	---------------	------	------

- ▼ Alerts (12)
 - > Content Security Policy (CSP) Header Not Set (2)
 - > Cross-Domain Misconfiguration
 - > HTTP Only Site
 - > Missing Anti-clickjacking Header (2)
 - > Server Leaks Information via "X-Powered-By" HTTP Response
 - > Strict-Transport-Security Header Not Set (3)
 - > Timestamp Disclosure - Unix (6)
 - > X-Content-Type-Options Header Missing (Systemic)
 - > Information Disclosure - Suspicious Comments
 - > Modern Web Application (2)
 - > Re-examine Cache-control Directives (4)
 - > Retrieved from Cache (4)

No default
credentials found!

OWASP ZAP



- SQL Injections
- Cross-Site Scripting
- Broken authentication
- Test specific credentials

OWASP ZAP – When given the credentials

The screenshot displays the OWASP ZAP 2.17.0 interface. The main window is titled "Automated Scan" and contains instructions for launching a scan. A dialog box titled "Authentication Tester" is open, showing the configuration for an authentication test. The URL to attack is set to "http://localhost:3000". The context is "Authentication Test", the auth method is "Browser Based", and the client script is "Record...". The browser is set to "Firefox". The username is "demo" and the password is masked with "....". The time to wait is 2 seconds and the step delay is 0 seconds. The results section shows a "Passed" status for the Username Field, Password Field, Session Handling, and Verification URL.

Automated Scan

This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'. Please be aware that you should only attack applications that you have been specifically given permission to test.

URL to attack:

Authentication Tester

Test Domains Steps Diagnostics

Login URL:

Context:

Auth Method:

Client Script:

Browser:

Username:

Password:

Time to Wait (seconds):

Step Delay (seconds):

Record Diagnostics: ☐

Results

Status: ● Passed

Username Field: ● Identified

Password Field: ● Identified

Session Handling: ● Identified

Verification URL: ● Identified

We need to give it the correct credentials...

Channel	Bytes	Payload
#1.4	33/	420["get",{"method":"get","headers":{"Authorization":"Bearer ...
#1.5	647	430["body":{"item":{"id":"1710441920200705025"},"created ...
#1.6	319	421["get",{"method":"get","headers":{"Authorization":"Bearer ...
#1.7	650	431["body":{"item":{"id":"1710441920200705025"},"create ...
#1.8	322	422["get",{"method":"get","headers":{"Authorization":"Bearer ...
#1.9	265	432["body":{"items":["included":{"users":["projectManager ...
#1.10	327	423["get",{"method":"get","headers":{"Authorization":"Bearer ...
#1.11	234	433["body":{"items":["included":{"users":["cards":["action ...
#1.12	327	424["get",{"method":"get","headers":{"Authorization":"Bearer ...
#1.13	186	434["body":{"items":["headers":{"X-Exit":"success","acces ...
#1.14	344	425["get",{"method":"get","headers":{"Authorization":"Bearer ...
#1.15	1,491	435["body":{"item":{"id":"1710441920200705025"},"created ...
#1.16	360	426["get",{"method":"get","headers":{"Authorization":"Bearer ...
#1.17	941	436["body":{"item":{"id":"1710461519772255235"},"created ...
#1.18	381	427["patch",{"method":"patch","headers":{"Authorization":"B ...
#1.19	132	42["projectUpdate",{"item":{"id":"1710461519772255235"}," ...
#1.20	669	437["body":{"item":{"id":"1710441920200705025"},"created ...
#1.21	2	1001
#1.22	2	1001

OWASP ZAP – Still Fails on some Apps

The screenshot shows the 'Authentication Tester' dialog box in OWASP ZAP. The 'Test' tab is selected. The configuration is as follows:

- Login URL: `http://localhost:3000`
- Context: `Authentication Test`
- Auth Method: `Browser Based`
- Client Script: (empty)
- Browser: `Firefox`
- Username: `username`
- Password: `.....`
- Time to Wait (seconds): `2`
- Step Delay (seconds): `0`
- Record Diagnostics: ☐

The 'Results' section shows the following status:

Component	Status
Status	Failed
Username Field	●
Password Field	●
Session Handling	●
Verification URL	●

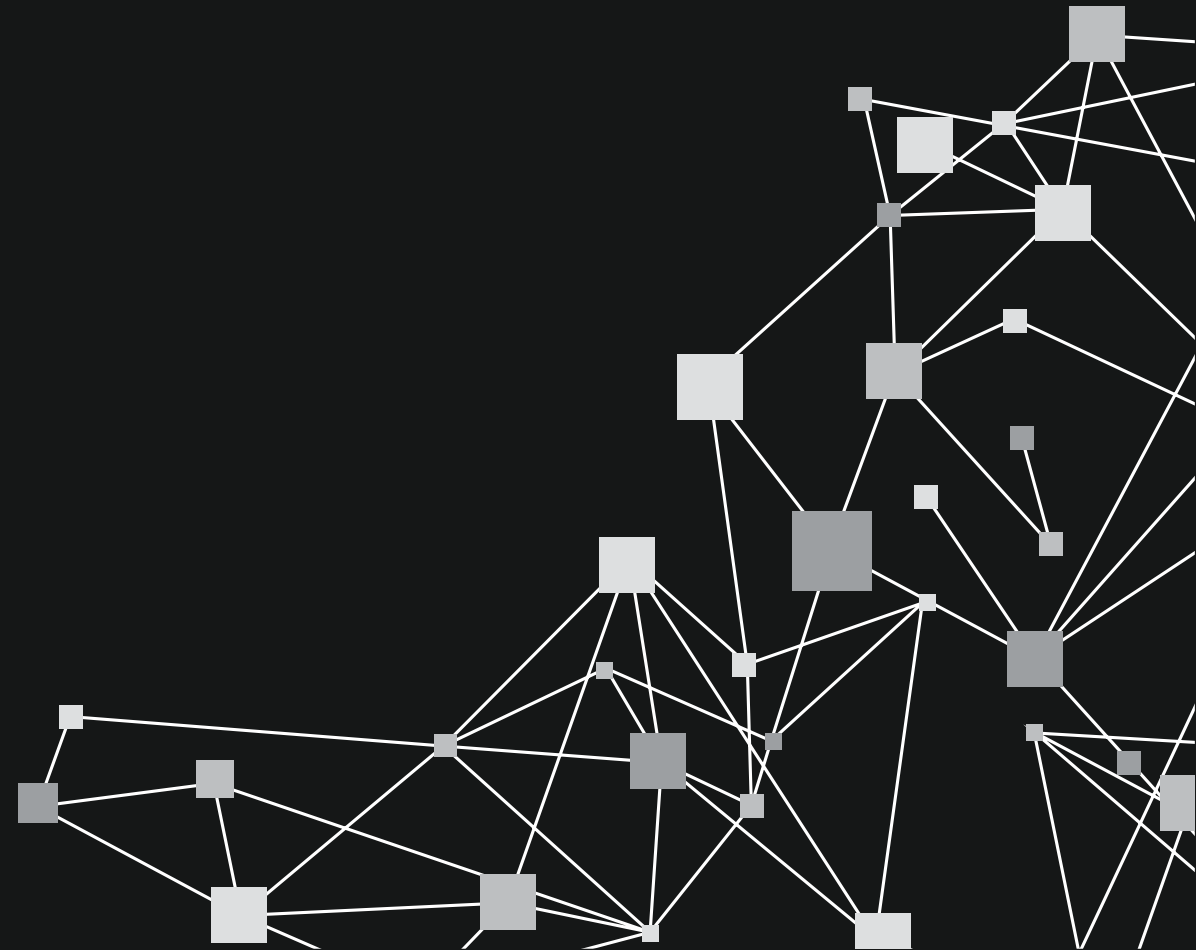
At the bottom, there are buttons for 'Test', 'Reset', and 'Cancel'.

- Correct credentials must be provided
 - Doesn't work for all sites out of the box
- Should work on more sites without providing the credentials!
- Automatic Web App enumeration (e.g. for subnet)

Project

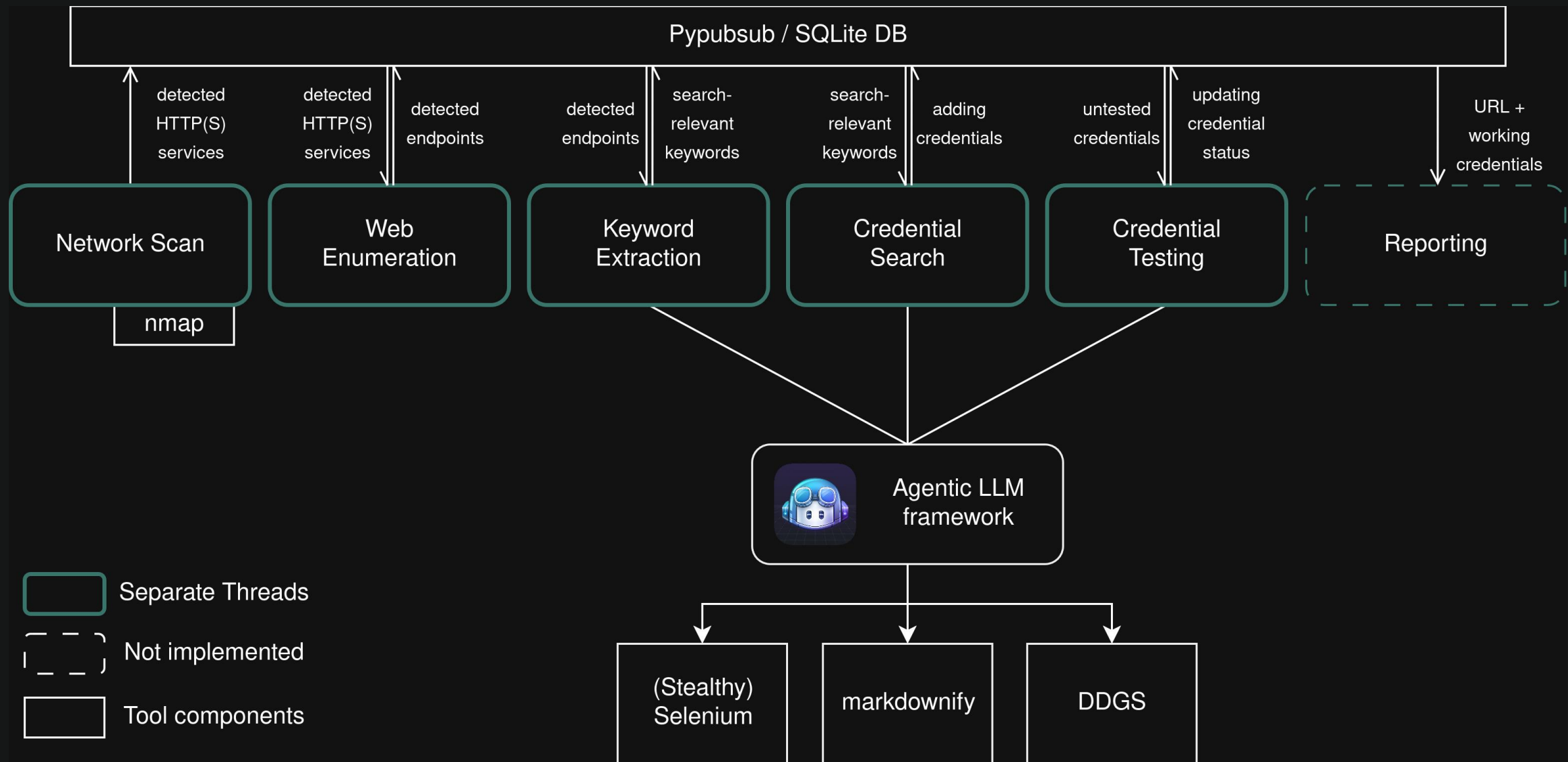
**Design IT.
Create Knowledge.**

www.hpi.de



- Cover diverse applications using LLMs
 - Task A:** Find credentials using agentic web search
 - Task A.1: Identify useful keywords for web search
 - Task A.2: Extract default credentials from search results
 - Task B:** Test credentials using agentic browser automation
 - Task B.1: Submit credentials to varying form types
 - Task B.2: Determine login success
- Build long-running scanner
 - Stateful
 - Runs continuously in background

Architecture



Architecture – Database



- DB is nice to organize/unify state
- Challenge: SQLite not optimized for concurrent access
 - DB locking failures
 - Maximum number of connections exceeded
- Solutions:
 - Reduce number of concurrent threads
 - Minimize write frequency
 - Use write lock



Module 1: Network Scan



Input: subnet to scan, ports to scan (default: all)

Output: service records written to DB

- Based on nmap3 library
- Scans hosts one-by-one and with "-Pn"
- Filters for HTTP(S) endpoints



Module 1: Network Scan - Challenges



- none; minimal implementation works fine



Module 2: Web Enumeration



Input: services detected by netscan module

Output: endpoint records written to DB

- Uses python-requests to try paths from a wordlist
- Found paths are requested using full browser (for JS rendering)
- Links from the page are visited (crawling)
- Performs login panel detection



Module 2: Web Enumeration - Challenges



- Redirects need to be handled (also: HTML/JS-based redirects)
- Soft 404 detection
 - Some apps always return a login panel
- Page deduplication
- Some apps require specific 'Host' headers :/



Module 3: Keyword Extraction



Input: endpoints found by webenum module

Output: updates keywords field in endpoints record

- Gives page source to LLM and asks for relevant keywords

```
PROMPT_TEMPLATE = """
<<<BEGIN CONTENT>>>
%s
<<<END CONTENT>>>
You are a pentester and have encountered an unknown web application.
Your goal is to find documentation or source code for this application that might contain default credentials.
Identify keywords or links for a web search. If an application name appears (title, logo text, headings),
include it as a keyword even if it is the only one. The keywords/links must be specific to this application.
Do not include keywords that are unspecific or not informative.
The web page has the content given above.
Your first line of output must contain the number of identified keywords/links as a decimal integer.
The following lines should contain one keyword/link per line.
If there are no specific keywords on the page, output 0. Output no more than 5 keywords.
"""
```



Module 3: Keyword Extraction – Challenges



- Must consider context window of LLM
- Webenum bug can lead to many endpoints which cause excessive API cost
- LLMs are dumb (if you ask for up to 5 keywords, they always output 5 even though in their thinking section they identified only 2)



Module 4: Credential Search



Input: services with all endpoints processed by keyword extractor

Output: adds to credentials field of service record

- Gives extracted keywords to LLM and asks to perform web search
- Provided tools: *search_web*, *submit_credentials*, *fetch_url_as_markdown*



Module 4: Credential Search



Input: services with all endpoints processed by keyword extractor

Output: adds to credentials field of service record

- Gives extracted keywords to LLM and asks to perform web search
- Provided tools: *search_web*, *submit_credentials*, *fetch_url_as_markdown*

Challenges:

- Even as markdown, pages can blow up context window
- Some applications have multiple candidates



Module 5: Credential Testing



Input: endpoints with untested credentials

Output: adds to tested_credentials field of endpoint record

- Asks LLM to submit given credentials to endpoint
- Provided tools: *insert_text_into_field*, *click_button*
- Tests login success heuristically



Module 5: Credential Testing



Input: endpoints with untested credentials

Output: adds to tested_credentials field of endpoint record

- Asks LLM to submit given credentials to endpoint
- Provided tools: *insert_text_into_field*, *click_button*
- Tests login success heuristically

Challenges:

- Multi-step logins
- Raw HTML can blow up context window (again)
- Responses to successful/invalid logins can vary wildly



Module 5: Credential Testing - Success Heuristic



- Using thresholded score to consider multiple signals
- Exploit baselining to eliminate false positive signals
- Positive signals:
 - Big simhash distance between page sources
 - Login sets new cookie
 - Page title changed
 - Path changed
 - Post-login page has no password input
 - Post-login page does not contain common error messages



Module 5: Credential Testing - Success Heuristic



- Using thresholded score to consider multiple signals
- Exploit baselining to eliminate false positive signals
- Positive signals:
 - Big simhash distance between page sources
 - Login sets new cookie
 - Page title changed
 - Path changed
 - Post-login page has no password input
 - Post-login page does not contain common error messages
- Negative signals:
 - Login sets no new cookie
 - Post-login page contains common error messages



Bonus: Web Dashboard



- It is difficult to see what's happening in the logs
 - Because parallelism etc.
- Solution:
 - Dashboard to visualize run (inspired by team 2)
 - Works real-time!



Scanner Logs

Base: /home/team1/team-1/artifacts/successful_scan

RUNS

Time

A-Z

Zabbix-758762

2026-02-11 19:00:46

db ok

SonarQube-982665

2026-02-11 18:54:54

db ok

Readmine-788641

2026-02-11 18:48:39

db ok

pyLoad-275055

2026-02-11 18:46:15

db ok

PasswordCockpit-969951

2026-02-11 18:43:37

db ok

ownCloud-604813

2026-02-11 18:39:02

db ok

osTicket-828994

2026-02-11 18:36:29

db ok

Joplin-861202

2026-02-11 18:32:36

db ok

Grafana-459825

2026-02-11 18:30:07

db ok

Filadex-896920

2026-02-11 18:28:18

db ok

osTicket-828994

Rename run

Rename

SCANNER RUN

Artifacts folder: /home/team1/team-1/artifacts/successful_scan/osTicket-828994

SERVICES

1

ENDPOINTS

7

LOGIN PANELS

3

WORKING CREDENTIALS

1

SCREENSHOTS

18

Found credentials

1

http://127.0.0.1:8080/scp/login.php

CREDENTIALS

ostadmin:Admin1

Login panels

3

http://127.0.0.1:8080/login.php

ENDPOINT

Login panel

http://127.0.0.1:8080/scp/login.php

ENDPOINT

Login panel

http://127.0.0.1:8080/account.php

ENDPOINT

Login panel

Services

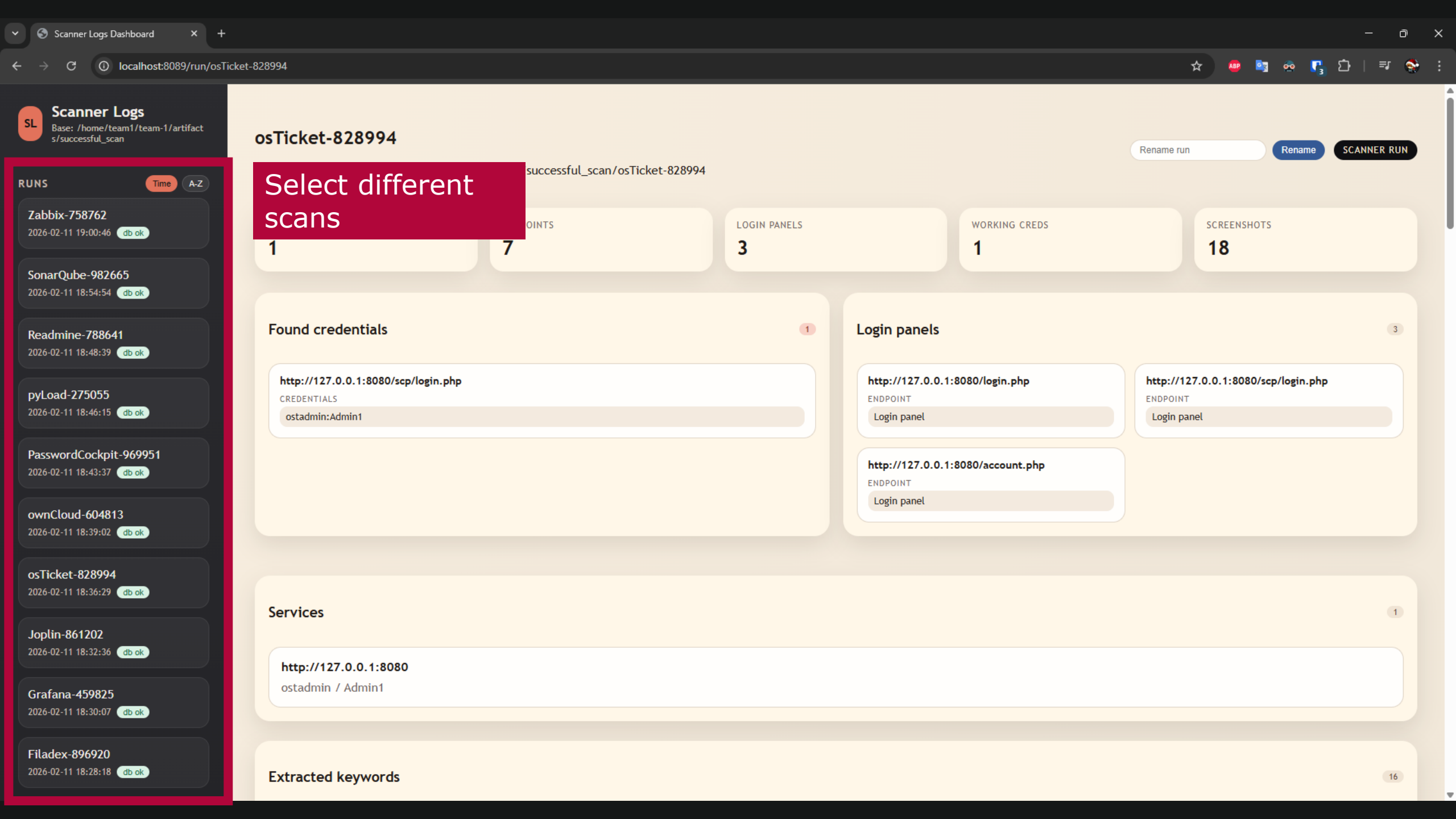
1

http://127.0.0.1:8080

ostadmin / Admin1

Extracted keywords

16



RUNS Time A-Z

- Zabbix-758762
2026-02-11 19:00:46 db ok
- SonarQube-982665
2026-02-11 18:54:54 db ok
- Readmine-788641
2026-02-11 18:48:39 db ok
- pyLoad-275055
2026-02-11 18:46:15 db ok
- PasswordCockpit-969951
2026-02-11 18:43:37 db ok
- ownCloud-604813
2026-02-11 18:39:02 db ok
- osTicket-828994
2026-02-11 18:36:29 db ok
- Joplin-861202
2026-02-11 18:32:36 db ok
- Grafana-459825
2026-02-11 18:30:07 db ok
- Filadex-896920
2026-02-11 18:28:18 db ok

osTicket-828994

Rename run Rename SCANNER RUN

Select different
scans

1

7

POINTS

LOGIN PANELS
3

WORKING CRED
1

SCREENSHOTS
18

Found credentials 1

http://127.0.0.1:8080/scp/login.php
CREDENTIALS
ostadmin:Admin1

Login panels 3

http://127.0.0.1:8080/login.php
ENDPOINT
Login panel

http://127.0.0.1:8080/scp/login.php
ENDPOINT
Login panel

http://127.0.0.1:8080/account.php
ENDPOINT
Login panel

Services 1

http://127.0.0.1:8080
ostadmin / Admin1

Extracted keywords 16

Scanner Logs

Base: /home/team1/team-1/artifacts/successful_scan

RUNS

Time

A-Z

Zabbix-758762

2026-02-11 19:00:46

db ok

SonarQube-982665

2026-02-11 18:54:54

db ok

Readmine-788641

2026-02-11 18:48:39

db ok

pyLoad-275055

2026-02-11 18:46:15

db ok

PasswordCockpit-969951

2026-02-11 18:43:37

db ok

ownCloud-604813

2026-02-11 18:39:02

db ok

osTicket-828994

2026-02-11 18:36:29

db ok

Joplin-861202

2026-02-11 18:32:36

db ok

Grafana-459825

2026-02-11 18:30:07

db ok

Filadex-896920

2026-02-11 18:28:18

db ok

osTicket-828994

Rename run

Rename

SCANNER RUN

Artifacts folder: /home/team1/team-1/artifacts/successful_scan/osTicket-828994

SERVICES

1

ENDPOINTS

7

LOGIN PANELS

3

WORKING CREDENTIALS

1

SCREENSHOTS

18

Found credentials

1

http://127.0.0.1:8080/scp/login.php

CREDENTIALS

ostadmin:Admin1

Quick stats overview

Login panels

3

http://127.0.0.1:8080/login.php

ENDPOINT

Login panel

http://127.0.0.1:8080/scp/login.php

ENDPOINT

Login panel

http://127.0.0.1:8080/account.php

ENDPOINT

Login panel

Services

1

http://127.0.0.1:8080

ostadmin / Admin1

Extracted keywords

16

Scanner Logs

Base: /home/team1/team-1/artifacts/successful_scan

RUNS

TimeA-Z

Zabbix-758762

2026-02-11 19:00:46db ok

SonarQube-982665

2026-02-11 18:54:54db ok

Readmine-788641

2026-02-11 18:48:39db ok

pyLoad-275055

2026-02-11 18:46:15db ok

PasswordCockpit-969951

2026-02-11 18:43:37db ok

ownCloud-604813

2026-02-11 18:39:02db ok

osTicket-828994

2026-02-11 18:36:29db ok

Joplin-861202

2026-02-11 18:32:36db ok

Grafana-459825

2026-02-11 18:30:07db ok

Filadex-896920

2026-02-11 18:28:18db ok

osTicket-828994

Artifacts folder: /home/team1/team-1/artifacts/successful_scan/osTicket-828994

Rename run

Rename

SCANNER RUN

SERVICES

1

ENDPOINTS

7

LOGIN PANELS

3

WORKING CREDENTIALS

1

SCREENSHOTS

18

Found credentials

1

http://127.0.0.1:8080/scp/login.php

CREDENTIALS

ostadmin:Admin1

Login panels

3

http://127.0.0.1:8080/login.php

ENDPOINT

Login panel

http://127.0.0.1:8080/scp/login.php

ENDPOINT

Login panel

http://127.0.0.1:8080/account.php

ENDPOINT

Login panel

Found services = e.g. Website

Services

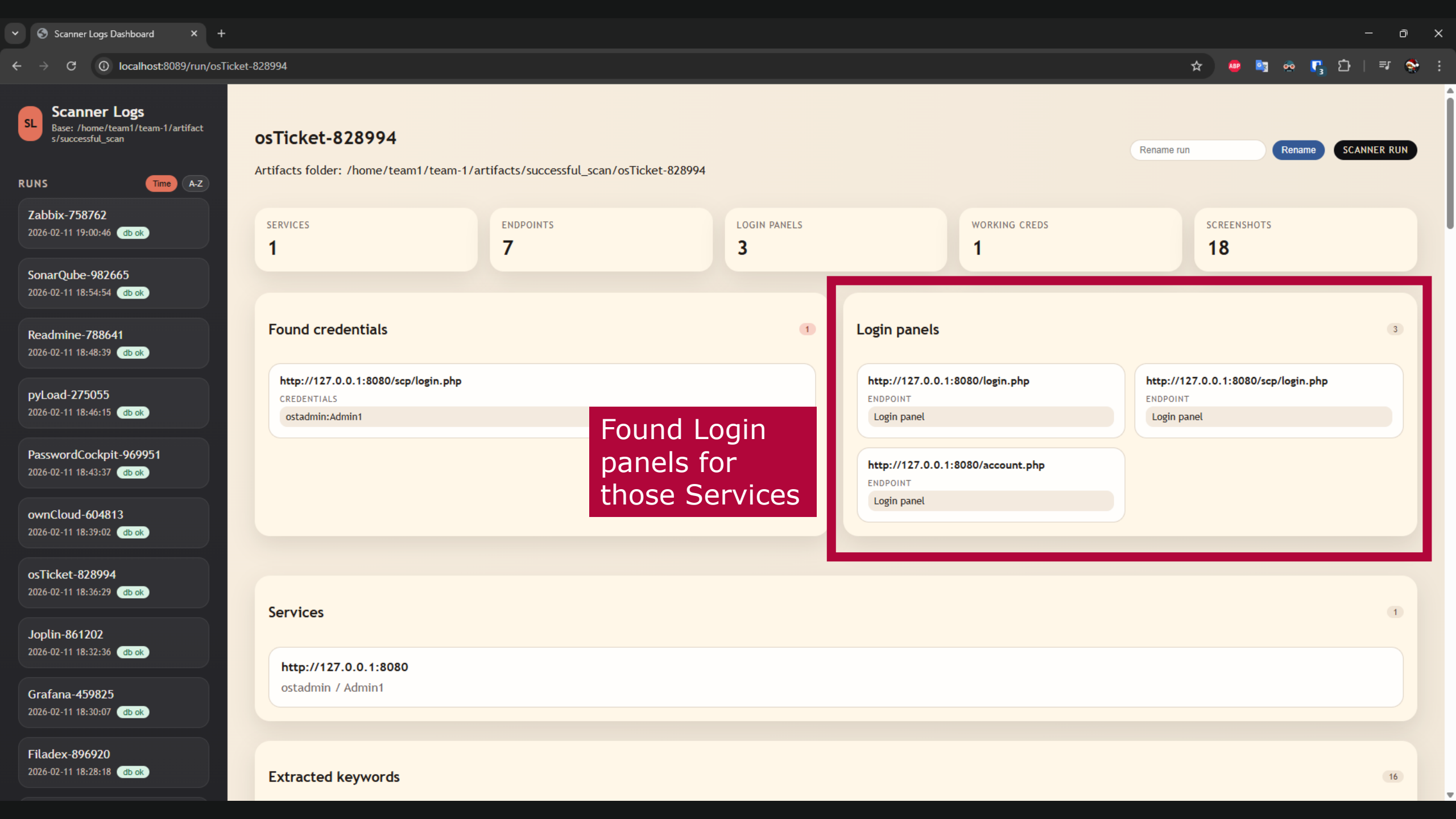
1

http://127.0.0.1:8080

ostadmin / Admin1

Extracted keywords

16



RUNS Time A-Z

- Zabbix-758762
2026-02-11 19:00:46 db ok
- SonarQube-982665
2026-02-11 18:54:54 db ok
- Readmine-788641
2026-02-11 18:48:39 db ok
- pyLoad-275055
2026-02-11 18:46:15 db ok
- PasswordCockpit-969951
2026-02-11 18:43:37 db ok
- ownCloud-604813
2026-02-11 18:39:02 db ok
- osTicket-828994
2026-02-11 18:36:29 db ok
- Joplin-861202
2026-02-11 18:32:36 db ok
- Grafana-459825
2026-02-11 18:30:07 db ok
- Filadex-896920
2026-02-11 18:28:18 db ok

osTicket-828994

Artifacts folder: /home/team1/team-1/artifacts/successful_scan/osTicket-828994

Rename run Rename SCANNER RUN

SERVICES1

ENDPOINTS7

LOGIN PANELS3

WORKING CREDENTIALS1

SCREENSHOTS18

Found credentials1

Found Login panels for those Services

Login panels3

http://127.0.0.1:8080/scp/login.php
CREDENTIALS
ostadmin:Admin1

http://127.0.0.1:8080/login.php
ENDPOINT
Login panel

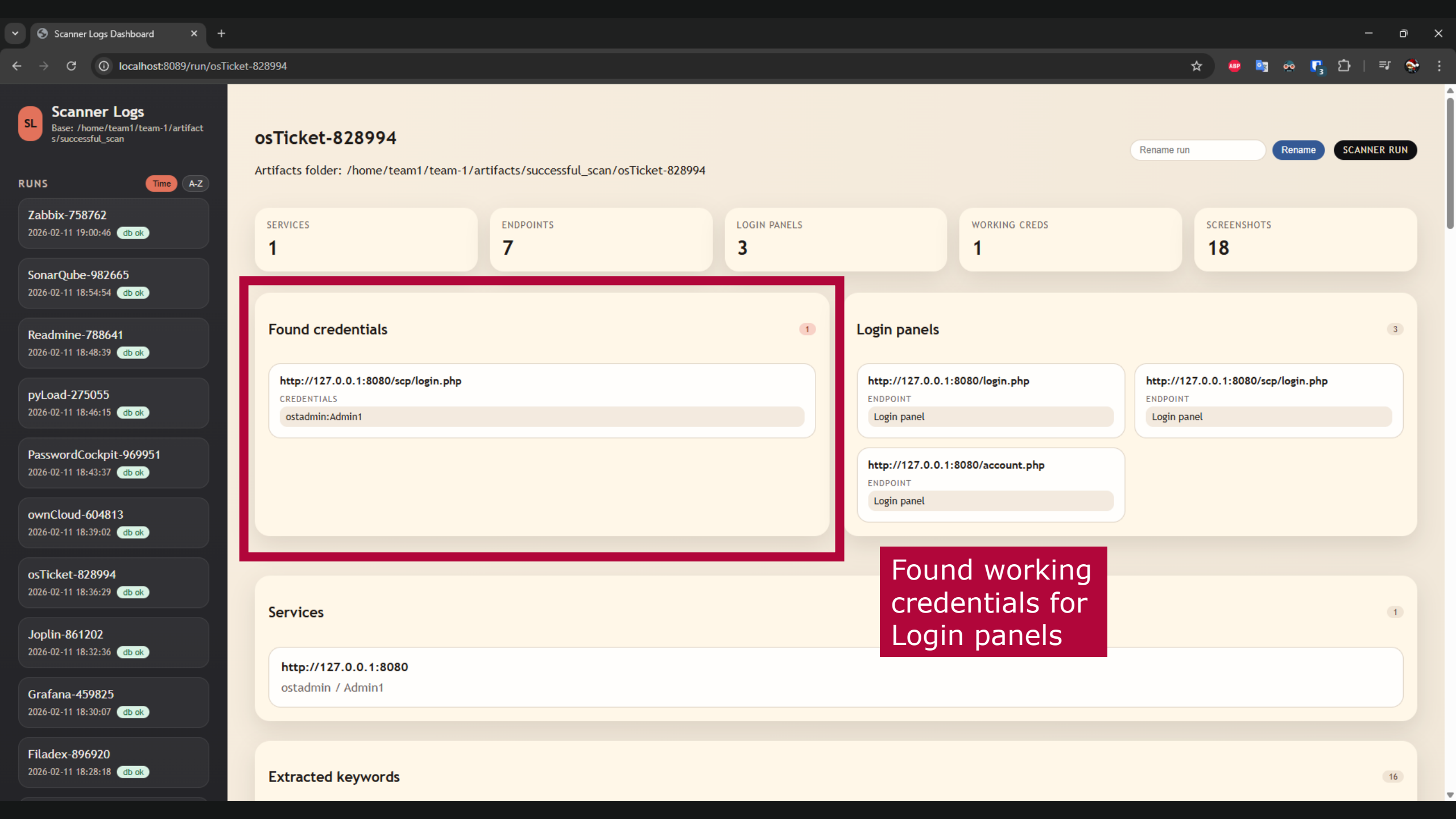
http://127.0.0.1:8080/scp/login.php
ENDPOINT
Login panel

http://127.0.0.1:8080/account.php
ENDPOINT
Login panel

Services1

http://127.0.0.1:8080
ostadmin / Admin1

Extracted keywords16



osTicket-828994

Artifacts folder: /home/team1/team-1/artifacts/successful_scan/osTicket-828994

Rename run

Rename

SCANNER RUN

SERVICES
1

ENDPOINTS
7

LOGIN PANELS
3

WORKING CREDENTIALS
1

SCREENSHOTS
18

Found credentials 1

http://127.0.0.1:8080/scp/login.php

CREDENTIALS

ostadmin:Admin1

Login panels 3

http://127.0.0.1:8080/login.php

ENDPOINT

Login panel

http://127.0.0.1:8080/scp/login.php

ENDPOINT

Login panel

http://127.0.0.1:8080/account.php

ENDPOINT

Login panel

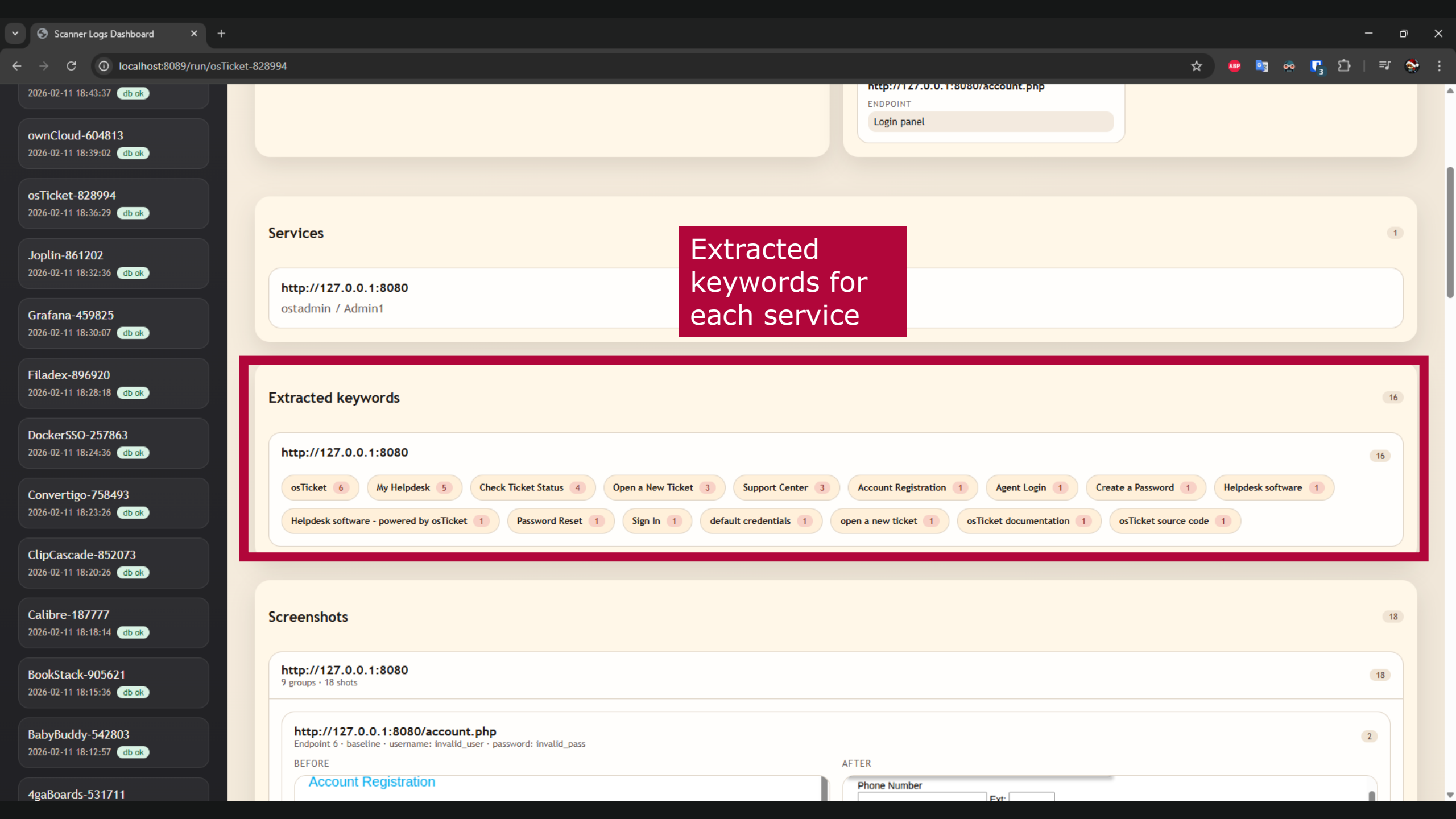
Services 1

http://127.0.0.1:8080

ostadmin / Admin1

Extracted keywords 16

Found working
credentials for
Login panels



2026-02-11 18:43:37 db ok

ownCloud-604813

2026-02-11 18:39:02 db ok

osTicket-828994

2026-02-11 18:36:29 db ok

Joplin-861202

2026-02-11 18:32:36 db ok

Grafana-459825

2026-02-11 18:30:07 db ok

Filadex-896920

2026-02-11 18:28:18 db ok

DockerSSO-257863

2026-02-11 18:24:36 db ok

Convertigo-758493

2026-02-11 18:23:26 db ok

ClipCascade-852073

2026-02-11 18:20:26 db ok

Calibre-187777

2026-02-11 18:18:14 db ok

BookStack-905621

2026-02-11 18:15:36 db ok

BabyBuddy-542803

2026-02-11 18:12:57 db ok

4gaBoards-531711

http://127.0.0.1:8080/account.php

ENDPOINT

Login panel

Services

1

http://127.0.0.1:8080

ostadmin / Admin1

Extracted
keywords for
each service

Extracted keywords

16

http://127.0.0.1:8080

16

osTicket 6

My Helpdesk 5

Check Ticket Status 4

Open a New Ticket 3

Support Center 3

Account Registration 1

Agent Login 1

Create a Password 1

Helpdesk software 1

Helpdesk software - powered by osTicket 1

Password Reset 1

Sign In 1

default credentials 1

open a new ticket 1

osTicket documentation 1

osTicket source code 1

Screenshots

18

http://127.0.0.1:8080

9 groups · 18 shots

18

http://127.0.0.1:8080/account.php

Endpoint 6 · baseline · username: invalid_user · password: invalid_pass

2

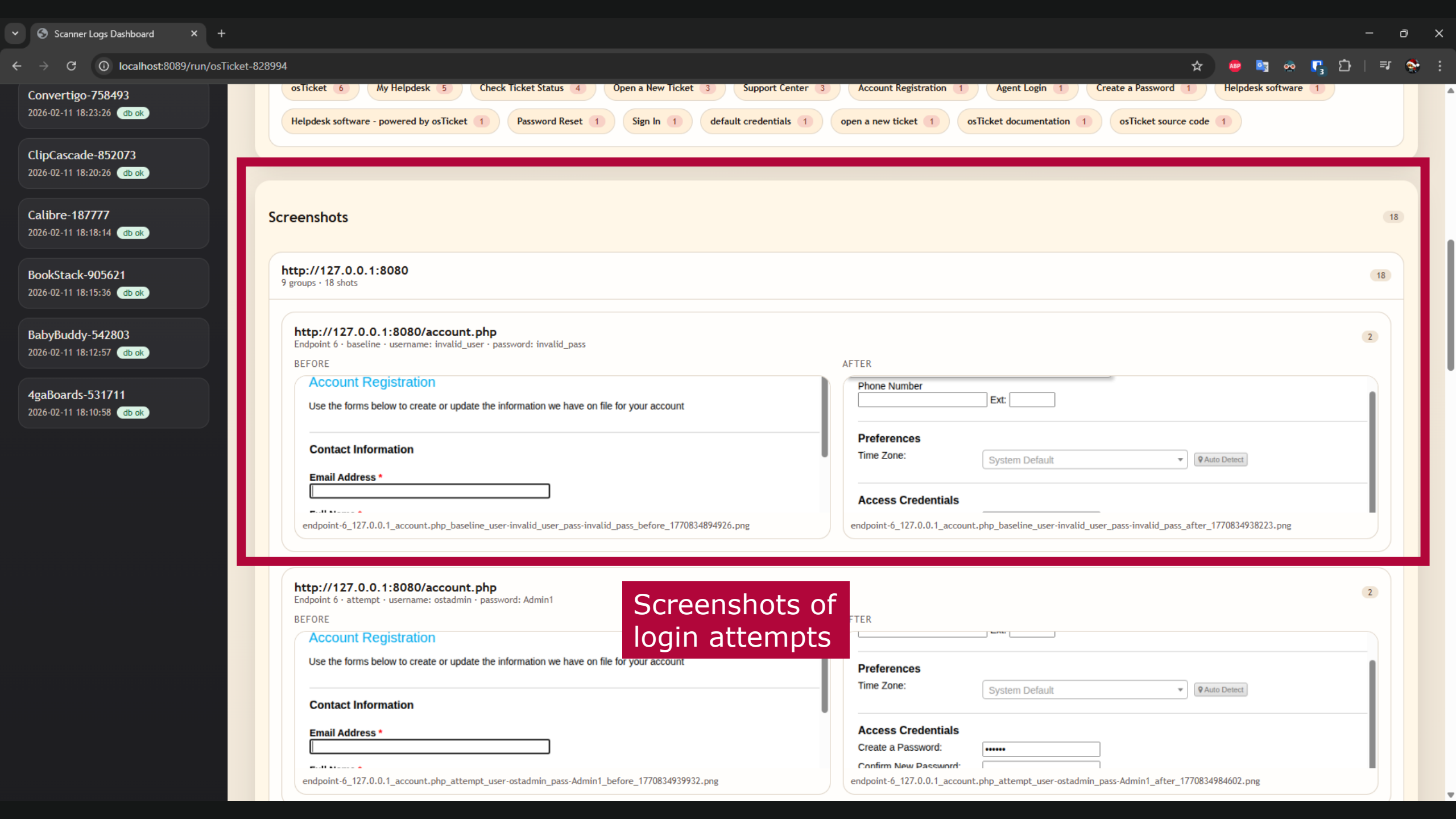
BEFORE

Account Registration

AFTER

Phone Number

Ext:



Convertigo-758493

2026-02-11 18:23:26 db ok

ClipCascade-852073

2026-02-11 18:20:26 db ok

Calibre-187777

2026-02-11 18:18:14 db ok

BookStack-905621

2026-02-11 18:15:36 db ok

BabyBuddy-542803

2026-02-11 18:12:57 db ok

4gaBoards-531711

2026-02-11 18:10:58 db ok

Screenshots

18

http://127.0.0.1:8080

9 groups · 18 shots

18

http://127.0.0.1:8080/account.php

Endpoint 6 · baseline · username: invalid_user · password: invalid_pass

2

BEFORE

Account Registration

Use the forms below to create or update the information we have on file for your account

Contact Information

Email Address *

endpoint-6_127.0.0.1_account.php_baseline_user-invalid_user_pass-invalid_pass_before_1770834894926.png

AFTER

Phone Number

Preferences

Time Zone:

System Default

Auto Detect

Access Credentials

endpoint-6_127.0.0.1_account.php_baseline_user-invalid_user_pass-invalid_pass_after_1770834938223.png

http://127.0.0.1:8080/account.php

Endpoint 6 · attempt · username: ostadmin · password: Admin1

2

BEFORE

Account Registration

Use the forms below to create or update the information we have on file for your account

Contact Information

Email Address *

endpoint-6_127.0.0.1_account.php_attempt_user-ostadmin_pass-Admin1_before_1770834939932.png

AFTER

Preferences

Time Zone:

System Default

Auto Detect

Access Credentials

Create a Password:

Confirm New Password:

endpoint-6_127.0.0.1_account.php_attempt_user-ostadmin_pass-Admin1_after_1770834984602.png

Screenshots of
login attempts

Scanner Logs Dashboard

localhost:8089/run/osTicket-828994

Email or Username

Password

Not yet registered? [Create an account](#)
I'm an agent — [sign in here](#)

endpoint-2_127.0.0.1_login.php_attempt_user-username_pass-password_before_1770834849835.png

username

Not yet registered? [Create an account](#)
I'm an agent — [sign in here](#)

endpoint-2_127.0.0.1_login.php_attempt_user-username_pass-password_after_1770834861577.png

http://127.0.0.1:8080/scp/login.php
Endpoint 5 • baseline • username: invalid_user • password: invalid_pass

BEFORE



endpoint-5_127.0.0.1_scp_login.php_baseline_user-invalid_user_pass-invalid_pass_before_1770834875056.png

http://127.0.0.1:8080/scp/login.php
Endpoint 5 • attempt • username: ostadmin • password: Admin1

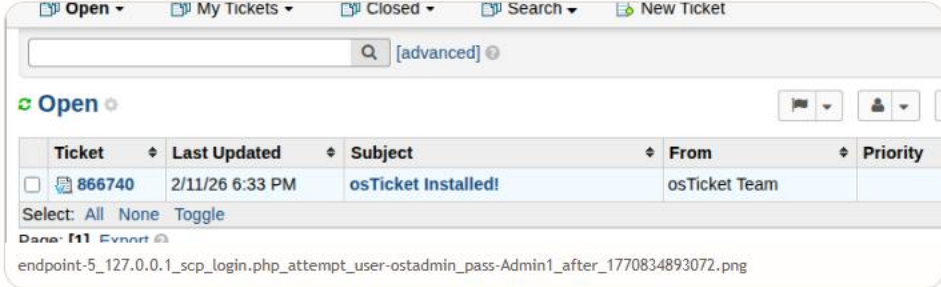
BEFORE



endpoint-5_127.0.0.1_scp_login.php_attempt_user-ostadmin_pass-Admin1_before_1770834885126.png

http://127.0.0.1:8080/scp/login.php
Endpoint 5 • attempt • username: ostadmin • password: Admin1

AFTER



endpoint-5_127.0.0.1_scp_login.php_attempt_user-ostadmin_pass-Admin1_after_1770834893072.png

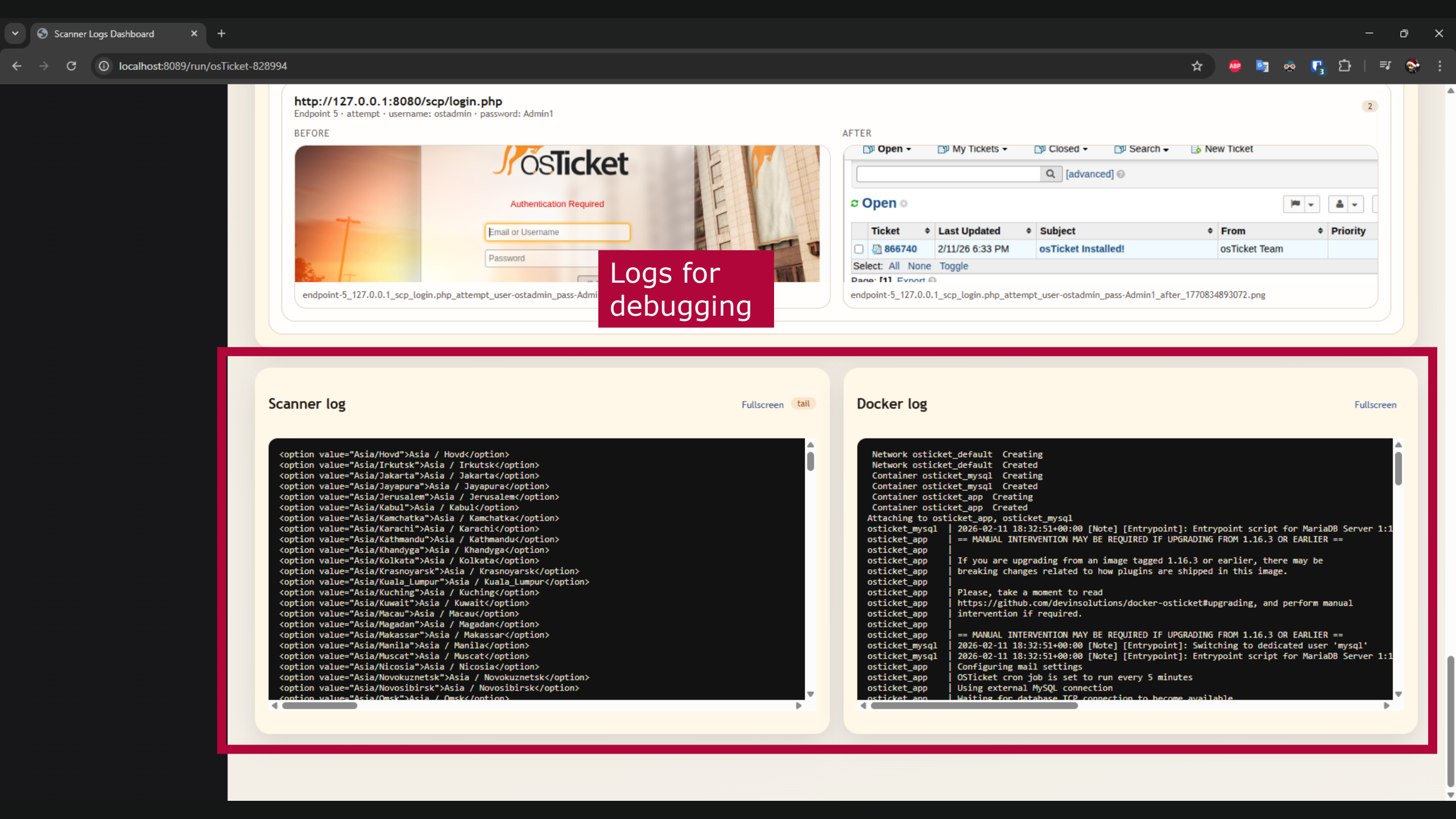
Success!

Scanner log

Fullscreen tail

Docker log

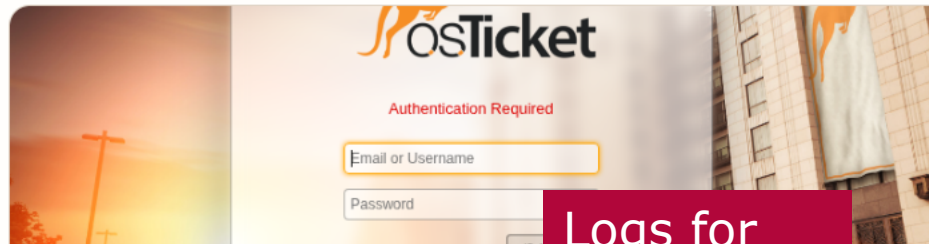
Fullscreen



http://127.0.0.1:8080/scp/login.php

Endpoint 5 · attempt · username: ostadmin · password: Admin1

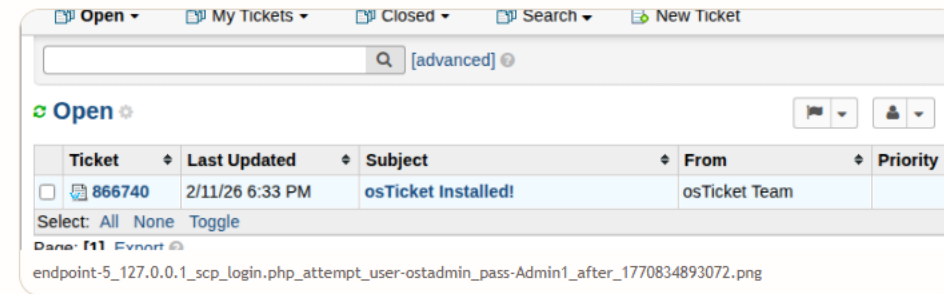
BEFORE



endpoint-5_127.0.0.1_scp_login.php_attempt_user-ostadmin_pass-Admin1

Logs for
debugging

AFTER



Scanner log

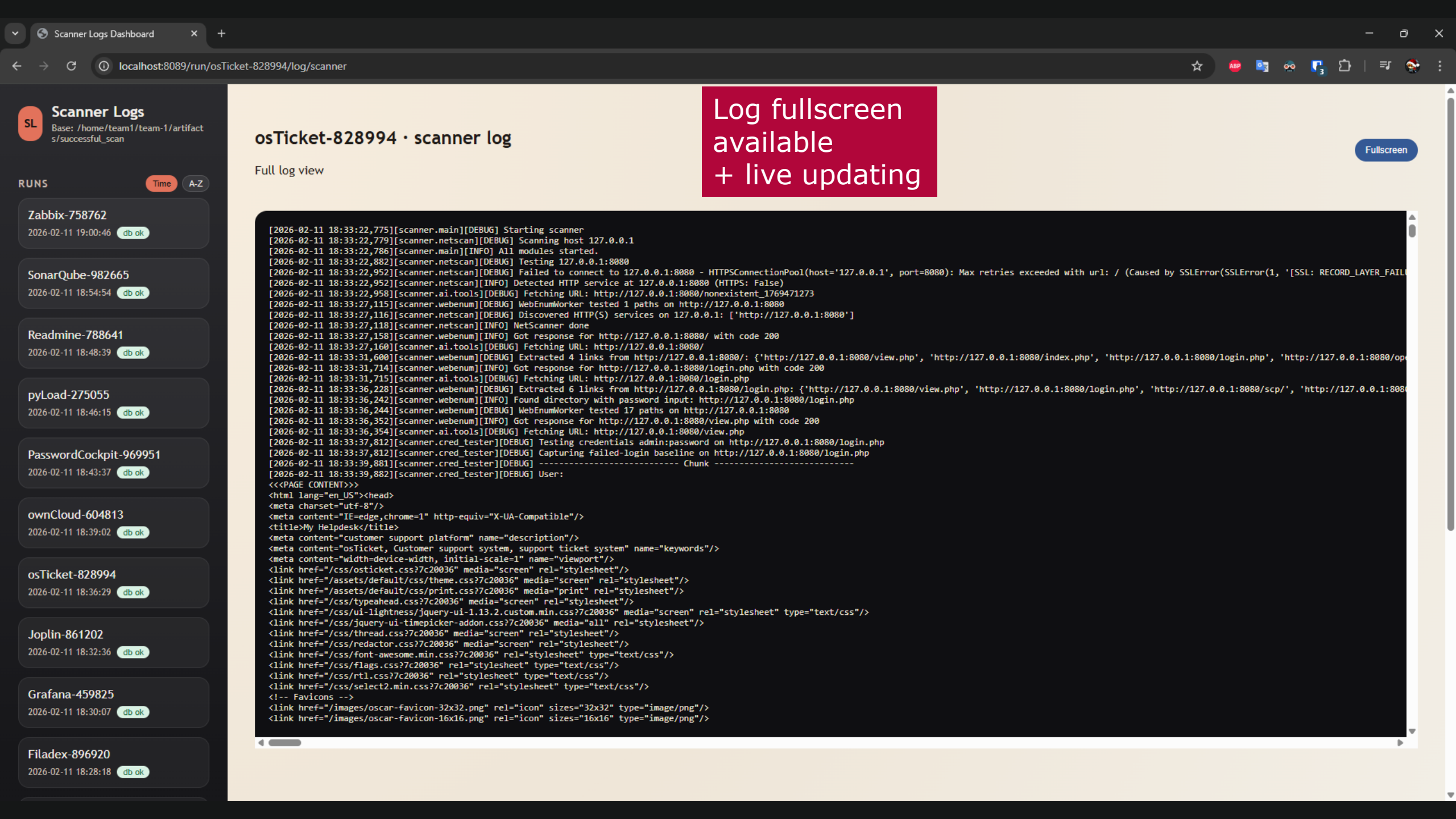
Fullscreen tail

```
<option value="Asia/Hovd">Asia / Hovd</option>
<option value="Asia/Irkutsk">Asia / Irkutsk</option>
<option value="Asia/Jakarta">Asia / Jakarta</option>
<option value="Asia/Jayapura">Asia / Jayapura</option>
<option value="Asia/Jerusalem">Asia / Jerusalem</option>
<option value="Asia/Kabul">Asia / Kabul</option>
<option value="Asia/Kamchatka">Asia / Kamchatka</option>
<option value="Asia/Karachi">Asia / Karachi</option>
<option value="Asia/Kathmandu">Asia / Kathmandu</option>
<option value="Asia/Khandyga">Asia / Khandyga</option>
<option value="Asia/Kolkata">Asia / Kolkata</option>
<option value="Asia/Krasnoyarsk">Asia / Krasnoyarsk</option>
<option value="Asia/Kuala Lumpur">Asia / Kuala Lumpur</option>
<option value="Asia/Kuching">Asia / Kuching</option>
<option value="Asia/Kuwait">Asia / Kuwait</option>
<option value="Asia/Macau">Asia / Macau</option>
<option value="Asia/Magadan">Asia / Magadan</option>
<option value="Asia/Makassar">Asia / Makassar</option>
<option value="Asia/Manila">Asia / Manila</option>
<option value="Asia/Muscat">Asia / Muscat</option>
<option value="Asia/Nicosia">Asia / Nicosia</option>
<option value="Asia/Novokuznetsk">Asia / Novokuznetsk</option>
<option value="Asia/Novosibirsk">Asia / Novosibirsk</option>
<option value="Asia/Omsk">Asia / Omsk</option>
```

Docker log

Fullscreen

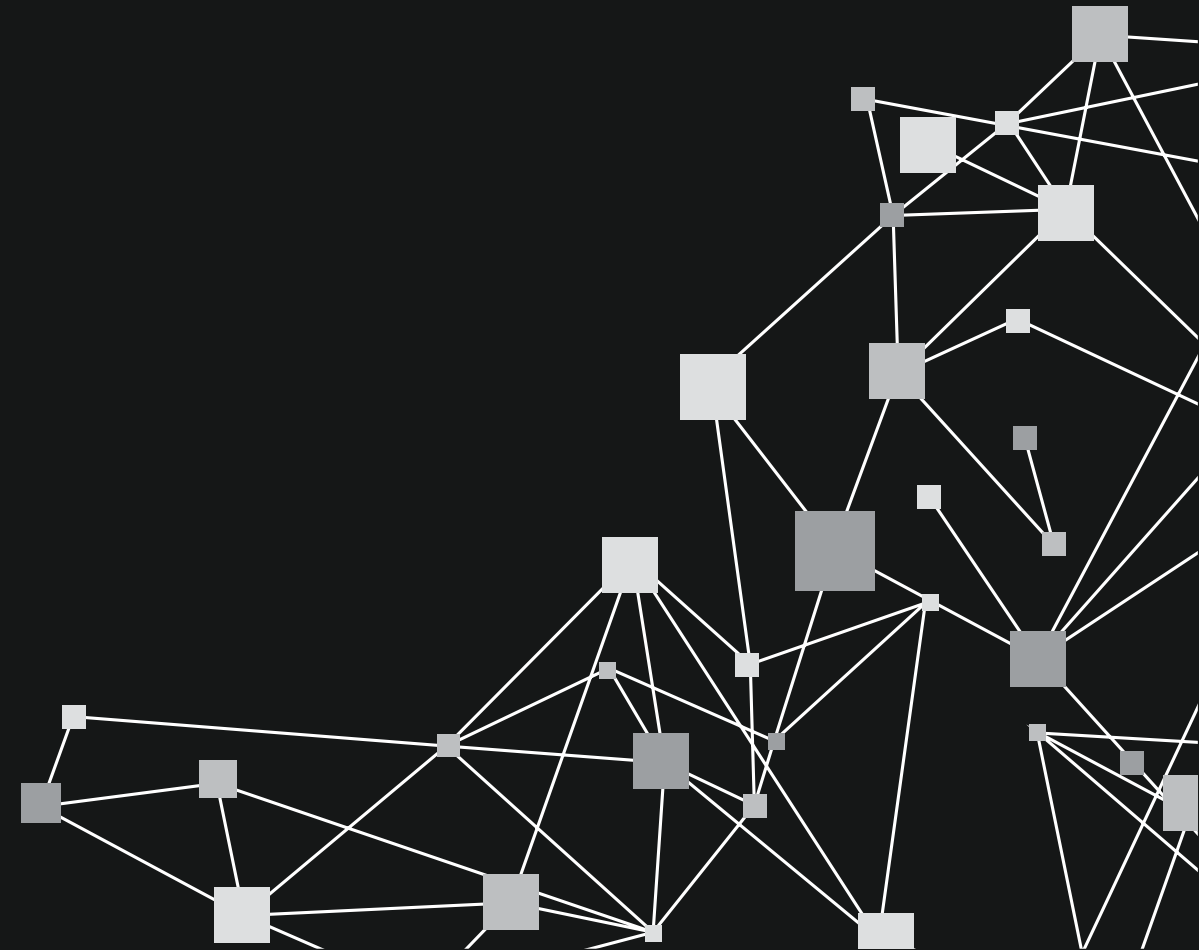
```
Network osticket_default Creating
Network osticket_default Created
Container osticket_mysql Creating
Container osticket_mysql Created
Container osticket_app Creating
Container osticket_app Created
Attaching to osticket_app, osticket_mysql
osticket_mysql | 2026-02-11 18:32:51+00:00 [Note] [Entrypoint]: Entrypoint script for MariaDB Server 1:1
osticket_app | == MANUAL INTERVENTION MAY BE REQUIRED IF UPGRADING FROM 1.16.3 OR EARLIER ==
osticket_app | If you are upgrading from an image tagged 1.16.3 or earlier, there may be
osticket_app | breaking changes related to how plugins are shipped in this image.
osticket_app | Please, take a moment to read
osticket_app | https://github.com/devinsolutions/docker-osticket#upgrading, and perform manual
osticket_app | intervention if required.
osticket_app | == MANUAL INTERVENTION MAY BE REQUIRED IF UPGRADING FROM 1.16.3 OR EARLIER ==
osticket_mysql | 2026-02-11 18:32:51+00:00 [Note] [Entrypoint]: Switching to dedicated user 'mysql'
osticket_mysql | 2026-02-11 18:32:51+00:00 [Note] [Entrypoint]: Entrypoint script for MariaDB Server 1:1
osticket_app | Configuring mail settings
osticket_app | OSTicket cron job is set to run every 5 minutes
osticket_app | Using external MySQL connection
osticket_app | Waiting for database TCP connection to become available
```



Testing Results

**Design IT.
Create Knowledge.**

www.hpi.de

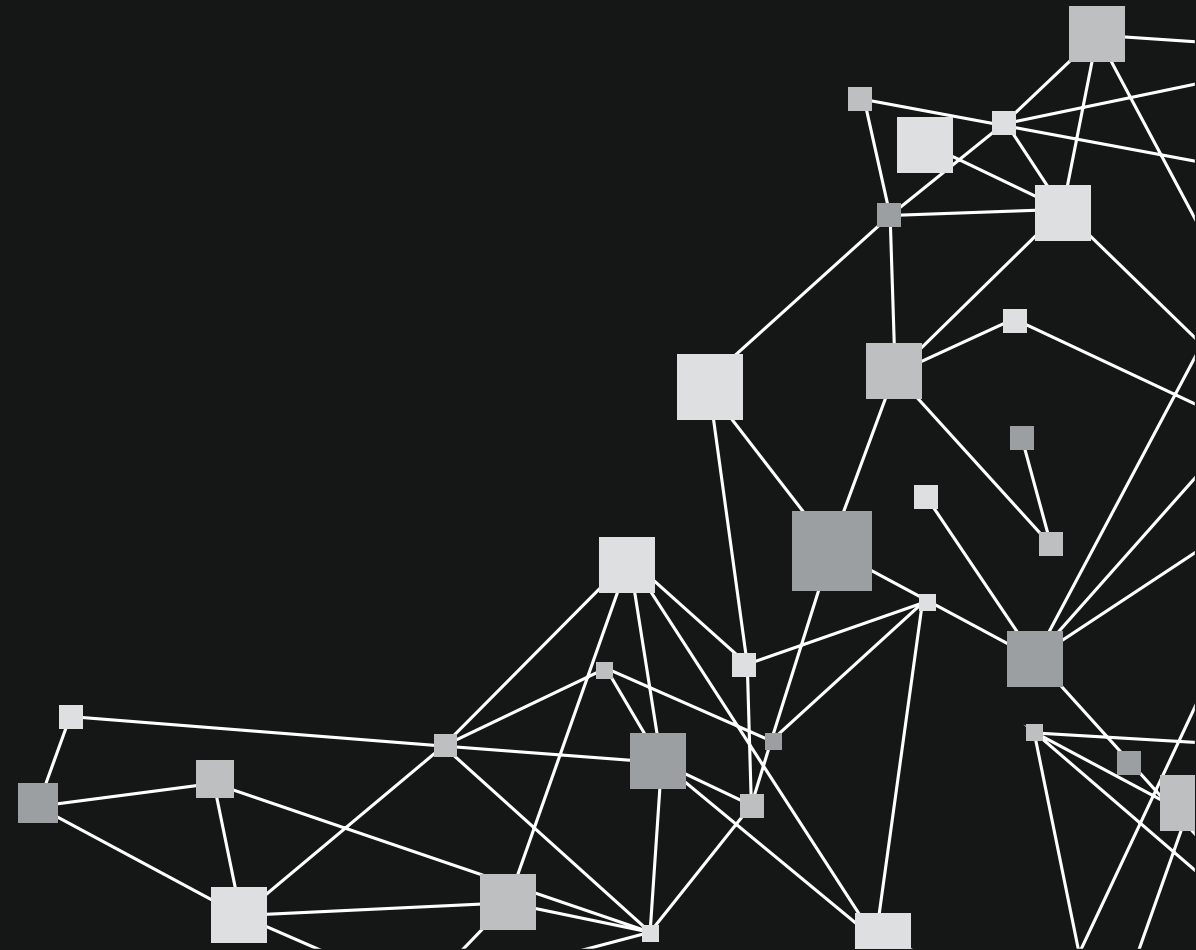


Service Name	Found Credentials	Verified Credentials	Found Login Panel	DB Path
4gaBoards	✓	✗	✓	/tmp/scanner-test-796185.db
BabyBuddy	✓	✓	✓	/tmp/scanner-test-586638.db
BookStack	✗	✗	✗	/tmp/scanner-test-317766.db
CalibrWeb	✗	✗	✗	/tmp/scanner-test-714216.db
ClipCascade	✗	✗	✗	/tmp/scanner-test-412040.db
Convertigo	✓	✓	✓	/tmp/scanner-test-612219.db
DockerSSOServer	✗	✗	✓	/tmp/scanner-test-573278.db
Filadex	✓	✓	✓	/tmp/scanner-test-165125.db
Grafana	✗	✗	✗	/tmp/scanner-test-237110.db
Joplin	✗	✗	✗	/tmp/scanner-test-112354.db
osTicket	✗	✗	✓	/tmp/scanner-test-124860.db
ownCloud	✗	✗	✗	ERROR
PasswordCockpit	✗	✗	✗	/tmp/scanner-test-560638.db
Pyload	✗	✗	✓	/tmp/scanner-test-427859.db
Readmine	✓	✓	✓	/tmp/scanner-test-951362.db
SonarQube	✗	✗	✗	ERROR
Zabbix	✗	✗	✗	/tmp/scanner-test-195807.db
All tests completed in 3530.45 seconds.				

Live Demo

**Design IT.
Create Knowledge.**

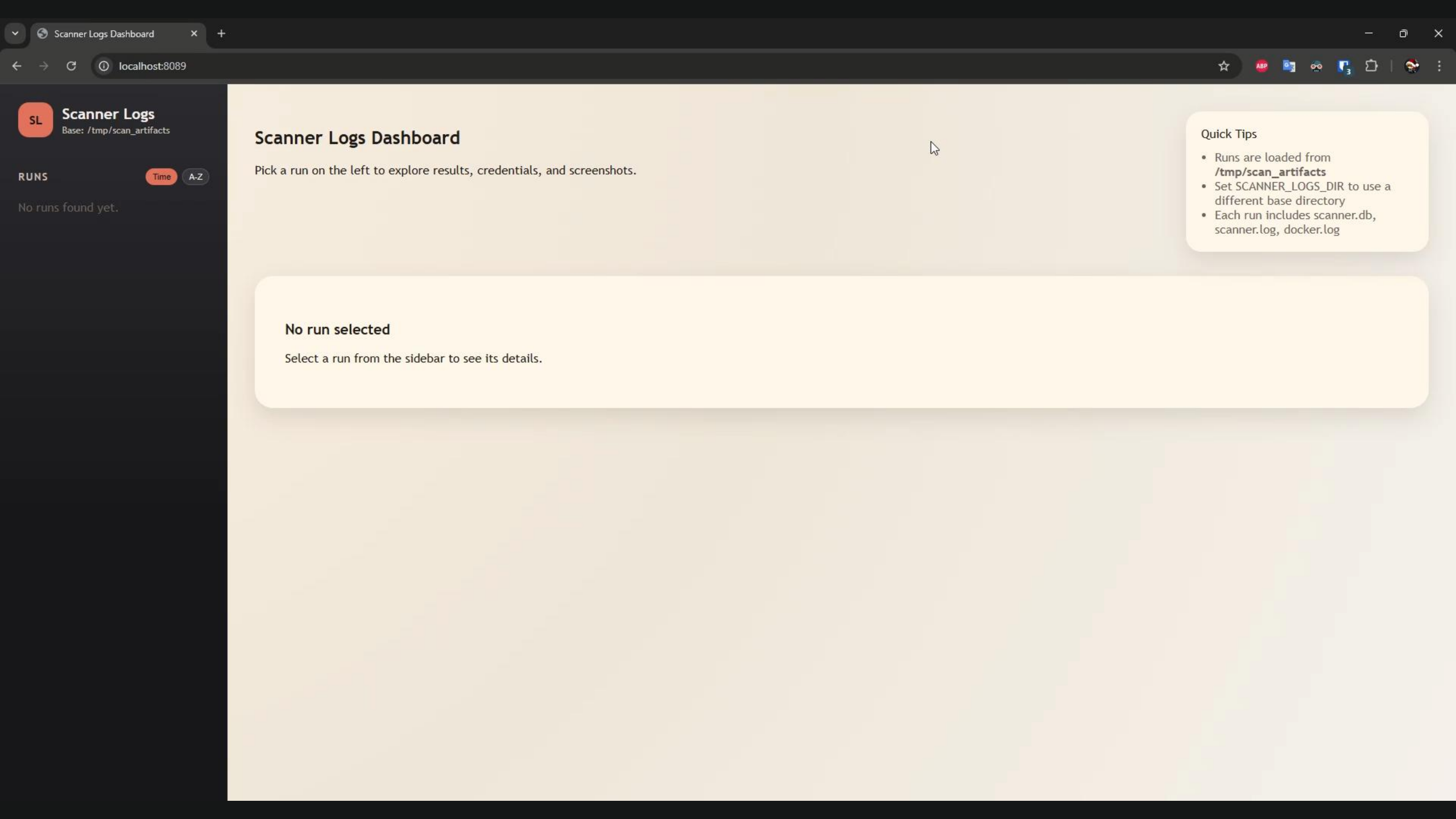
www.hpi.de



Zabbix



- Default credentials: Admin:zabbix



RUNS Time A-Z

No runs found yet.

Scanner Logs Dashboard

Pick a run on the left to explore results, credentials, and screenshots.

No run selected

Select a run from the sidebar to see its details.

Quick Tips

- Runs are loaded from **/tmp/scan_artifacts**
- Set **SCANNER_LOGS_DIR** to use a different base directory
- Each run includes **scanner.db**, **scanner.log**, **docker.log**

Outlook – Future Modules



- Reporting module
 - Informs admin about successful logins
- Subdomain enumeration
 - Some webapps only accessible with correct (sub)domain
 - There are tools for that
 - Not implemented yet
- Hostname detector

Outlook – Other



- More caching (e.g. LLM requests)
- Rate limiting
- Evaluate other LLMs (potentially fine tuning)
- Larger testing network (more apps)
- Account Lockout?

Q&A

Do you think our testing setup is
representable?

**Design IT.
Create Knowledge.**

www.hpi.de

